

2.7 Vulnerability Scanning

Control Type: Mandatory / Advisory for B	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
Control Definition Control Objective: Identify known vulnerabilities within the user's Swift environment by implementing a regular vulnerability scanning process and act upon results. In-scope components: • jump server • dedicated operator PCs • all systems hosting a Swift-related component (including interface, GUI, Swift and customer (client) connectors) • systems hosting a customer client connector • [Advisory: when technically possible, on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform hosting Swift-related VMs including the Alliance Connect Virtual on Premises VPN, and their management PCs] • bridging servers (such as middleware or file transfer servers other than customer connectors) used for and guardian of the secure data exchange between back-office and Swift-related components • [Advisory: General-purpose operator PCs as per the optional enhancement] Note: Vulnerability scans are performed in line with the Swift Customer Testing Policy. As such, Alliance Connect products, including the VPN boxes and their virtual instances, are not to be tested. Risk Drivers: • exploitation of known security vulnerabilities • Unknown security vulnerabilities or security misconfigurations						
Implementation Guidance Control Statement: Secure zone (including dedicated operator PC) systems are scanned for vulnerabilities at OS and application level using an up-to-date, reputable scanning tool and results, reported by the tool, are considered for appropriate resolving actions. Control Context: The detection of known OS and application vulnerabilities allows vulnerabilities to be analysed, treated, and mitigated. The mitigation of vulnerabilities reduces the number of pathways that a malicious actor can use during an attack. A vulnerability scanning process that is comprehensive, repeatable, and performed in a timely manner is necessary to continuously detect known vulnerabilities and to allow for further action. This control complements the control 2.2 by enabling the identification of vulnerabilities potentially not fixed yet. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). • Vulnerability scanning is performed at least annually or after any significant change to the environment (for example, introduction of new servers or components, and network design changes that modify or increase the range of in-scope components).						

- Vulnerability scanning tools are from a reputable vendor and are updated with scan profiles within one month prior to scanning.
- The most appropriate type of vulnerability scanning (such as using credentials) is selected for the environment. Any administrative credentials used for scanning are appropriately protected.
- Sufficient risk-based safeguards are in place to minimise any operational impact (for example, running scans in safe mode, or omitting systems that may be negatively affected from the scan).
- Beyond vulnerability identification through scanning, all penetration tests or effective vulnerability tests on or through Swift-related services and products are consistent with the [Swift Customer Testing Policy](#).
- The outcome of the vulnerability scanning is documented (with restricted access) and analysed for appropriate action and remediation (such as applying security updates in line with control 2.2).
- Once per quarter, month, or real-time (preferred) scanning is recommended.

Optional Enhancements:

- Vulnerability scanning includes network devices protecting the secure zone (such as routers and switches) or the customer client connectors.
- Vulnerability scanning includes the general-purpose operator PCs used to connect to the user's, or service provider's Swift infrastructure or Swift-related application. As an alternative, security updates are regularly applied on the general-purpose operator PCs. In the latter case, only supported and regularly patched applications are deployed on those PCs.
- Apply the control to all bridging servers (such as other middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.